基于 CodeQL 与 LLM 的自主漏洞审计agent

一. 实验内容

自主选择一个 C/C++ 开源项目，设计并实现一个连接静态分析工具（CodeQL）与大语言模型（LLM）的自主漏洞审计Agent。

要求在选定项目后，实现以上任务流程的自动化。

二. 实验对象

目标项目：自主选择一个 C/C++ 开源项目。

版本要求：自主选择一个版本（最新或历史版本）。

工具：CodeQL CLI、主流 LLM（如 GPT-4, Claude, DeepSeek 等）。

三. 实验任务

针对自选的项目完成工具扫描，并利用大模型能力剔除噪声，精准定位真实bug。

1. **环境部署**：在 Linux 环境下自动完成目标项目的源码编译，并构建 CodeQL 语义数据库。
2. **扫描与解析**：调用 CodeQL 安全查询包，自动解析报告。
3. **自动化审计**：针对扫描结果，设计自动化的代码片段提取、上下文关联及 Prompt 调度逻辑，实现与 LLM API 的自动化交互。
4. **LLM漏洞研判：**设计一套标准或脚本，利用 LLM 识别并剔除假阳性，进行漏洞研判（例如漏洞触发逻辑的深层语义解释、严重性评估等）

四. 提交要求（GitHub 仓库）

1、架构与源码：

- **README.md**：展示 Agent 逻辑架构图及核心功能运行截图。
- **系统源码**：提交该系统的完整源码。
- **运行数据：**运行得到的所有数据文件。

2、实验报告：

- **项目选择理由**：说明目标项目的复杂度及预期漏洞情况。
- **结果分析**：统计漏洞捕获数、AI 审计准确率提升。

- **技术思考**：分析 LLM 在复杂逻辑下的“幻觉”表现及你的优化对策。